الشروط الخاصة :

- يلتزم المتعاقد بتنفيذ الأعمال محل المشروع بمهنية وكفاءة لضمان جودة تنفيذ الأعمال.
- يلتزم المتعاقد بنسب التوطين النظامية وفق المهن المستهدفة بنسب التوطين للمنشاءات و الكيانات.
- ينبغي على المتعاقد تقديم خطة توزيع فريق العمل خلال مراحل المشروع.
- يلتزم المتعاقد بالإمتثال لقرارات توطين العقود الصادرة بموجب الأوامر السامية وقرارات مجلس الوزراء، والقرارات الصادرة من وزارة الموارد البشرية والتنمية الإجتماعية.
- يتلزم المتعاقد بتأمين القوى العاملة للمشروع وفقاً للأنظمة والسياسات والإجراءات المنظمة لذلك.
- يتم تنفيذ نطاق العمل حضورياً في مقر مجلس الضمان الصحي وخلال ساعات العمل الرسمية حسب طبيعة المشروع التي تتطلب ذلك.

المتطلبات العامة:

- يجب على مقدم العرض التأكد من أن أي وكيل، بما في ذلك الجهة الخارجية أو المقاول من الباطن، الذي يوفر له مجلس الضمان الصحي إمكانية الوصول إلى أنظمة المعلومات الخاصة بها، يوافق على تنفيذ ضمانات معقولة ومناسبة لضمان سرية وسلامة وتوافر أنظمة المعلومات.
- يجب أن يكون لدى مقدم العرض ضوابط أمنية وسيبرانية لحماية المعلومات الحساسة و/أو السرية التي تتم مشاركتها مع الجهة الخارجية.
- يجب على مقدمي العروض عدم نسخ أي بيانات لمجلس الضمان الصحي ويتم الحصول عليها أثناء أداء الخدمات بموجب طلب تقديم العروض هذا إلى أي وسائط، بما في ذلك محركات الأقراص الثابتة أو محركات الأقراص المحمولة أو أي جهاز إلكتروني آخر، بخلاف تلك المعتمدة من قبل مجلس الضمان الصحي.
- سيحتاج جميع الموظفين الذين سيكونون جزءًا من هذه المشاركة الموزعين في مباني مجلس الضمان الصحي إلى الإلتزام بسياسة الأمن السيبراني الخاصة بمجلس الضمان الصحي.
- سيحتاج جميع الموظفين الذين سيكونون جزءًا من هذه المشاركة إلى توقيع إقرار عدم الإفصاح مع مجلس الضمان الصحي.
- يجب على مقدم العرض إجراء فحوصات شاملة التي تشمل العنوان الوطني والتعليم والتوظيف أو الوظائف السابقة والفحوصات الجنائية وشهادة الخلو من السوابق لجميع الموظفين الذين سيتم عملهم في مجلس الضمان الصحي لتنفيذ الخدمات.
- يجب على مقدم العرض الكشف عن أصل جميع مكونات البرامج المستخدمة في المنتج أو الحلول بما في ذلك أي مكونات مفتوحة المصدر أو مكونات مرخصة من طرف ثالث.
- يجب على مقدم العرض الكشف عن أصل جميع مكونات البرامج المستخدمة في المنتج بما في ذلك أي مكونات مفتوحة المصدر أو مكونات مرخصة من طرف ثالث.
- يمتلك مجلس الضمان الصحي حقوق إجراء تقييم دوري للمخاطر السيبرانية إما عن بعد أو في موقع مكتب مقدم العرض. سيتم تقييم متطلبات الأمن السيبراني لمقدم العرض المذكور في هذه الأقسام أثناء تقييم المخاطر السيبرانية. يجب على مقدم العرض معالجة أي ثغرات تم تحديدها خلال تقييم مخاطر الأمن السيبراني هذا والتي يمكن أن تؤدي إلى مخاطر الأمن السيبراني على مجلس الضمان الصحي دون أي تكلفة إضافية.
- يجب أن يتمتع الحل المقترح من قبل مقدم العرض بالقدرة على دعم تشفير المعلومات الحساسة/السرية.
- يجب على مقدم العرض التأكد من أن تنفيذ العقد، بما في ذلك الحلول المطلوبة، يجب أن يكون متوافقاً مع جميع المتطلبات القانونية والتنظيمية المعمول بها.
- يجب أن يكون لدى مقدم العرض شهادة الأيزو (ISO27001) سارية المفعول صادرة عن مدقق خارجي مستقل معتمد.
- عند استخدام خدمات الحوسبة السحابية وخدمات الاستضافة يجب ان يتم فصل البيئة الخاصة بمجلس الضمان الصحي وخصوصا الخوادم الافتراضية عن غيرها من البيئات التابعه لجهات اخرى.

البيانات والخصوصية والسرية:

- يجب على مقدم العرض التعامل مع جميع المعلومات التي تم الحصول عليها كجزء من هذا المناقصة وأي عقد لاحق على أنها معلومات سرية ويجب أن يحتفظ بالمعلومات السرية بسرية تامة وألا يكشف عنها لأي طرف ثالث ولا يستخدم هذه البيانات لمصلحته الخاصة أو لمصلحة أخرى أو لأي استخدام آخر غير الغرض المتفق عليه.
- يجب على مقدم العرض حماية وتأمين جميع المعلومات السرية أثناء النقل (المجمعة والمنسوخة والمنقولة) وفي حالة عدم وجودها (المخزنة على الخوادم المادية)، بما في ذلك أثناء أي نقل إلكتروني للبيانات أو نقل الوسائط الإلكترونية أو المادية.
- لا يجوز لمقدم العرض نسخ أي بيانات لمجلس الضمان الصحي اللي تم الحصول عليها أثناء أداء الخدمات بموجب طلب تقديم العروض هذا إلى أي وسائط، بما في ذلك محركات الأقراص الثابتة أو محركات الأقراص المحمولة أو أي جهاز إلكتروني آخر، بخلاف ما تمت الموافقة عليه صراحةً من قبل مجلس الضمان الصحي.
- يجب على مقدم العرض الاحتفاظ بجميع النسخ أو النسخ من المعلومات السرية بنفس الأمان الذي يحتفظ به بالنسخ الأصلية. عند النقطة التي لم تعد فيها المعلومات السرية مفيدة لأغراضها الأساسية أو لأغراض الاحتفاظ بها، كما هو محدد بواسطة مجلس الضمان الصحي، يجب على مقدم العرض إتلاف هذه البيانات، مما يجعلها غير قابلة للاستخدام وغير قابلة للاسترداد.
- يلتزم مقدم العرض بتخزين البيانات داخل الحدود الجغرافية للملكة العربية السعودية وذلك لضمان المحافظة على السيادة الوطنية لهذه البيانات.

- يلتزم مقدم العرض بالمحافظة على سلامة البيانات وتوافرها بما يضمن إمكانية الوصول اليها عند الحاجة باستخدام الإجراءات الإدارية والتقنية والمادية التي تتوافق مع المعايير القياسية المتعارف عليها بشكل عام والممارسات التي يطبقها المجلس على البيانات الخاصة به، وما يصدر من الهيئة الوطنية للأمن السيبراني او من في حكمها.
- يلتزم مقدم العرض بتقييد إدارة صلاحيات العاملين على الحد الأدنى من الامتيازات اللازمة لأداء المهام والمسؤوليات المناطة بهم فيما يتعلق بالبيانات وذلك بالتنسيق مع مكتب ادارة البيانات لدى الطرف الأول.
- يجب على مقدم العرض الاحتفاظ بجميع المعلومات واستخدامها فقط لأغراض العقد/الاتفاقية وفقط وفقًا لما يسمح به مجلس الضمان الصحي . أي كشف عن أي معلومات لمثل هؤلاء الموظفين والوكلاء يجب أن يكون بشكل صارم على أساس مبدأ "الحاجة إلى المعرفة."
- يجب على مقدم العرض فقط عمل نسخ على النحو المصرح به على وجه التحديد بموجب موافقة كتابية مسبقة من قبل مجلس الضمان الصحي وبنفس الإشعارات السرية أو الملكية التي يمكن طباعتها أو عرضها على النسخة الأصلية.
- يجب على مقدم العرض الذي تم اختياره التوقيع على اتفاقية عدم الإفصاح خلال ١٥ يومًا من إصدار أمر الشراء/إخطار الترسية.

تطوير التطبيقات:

- يجب أن يكون لدى مقدمي العروض نظام شامل وآمن لدورة حياة التطوير بما يتوافق مع أفضل ممارسات والمعايير الدولية، بما في ذلك السياسات والتدريب وعمليات التدقيق والاختبار والتحديثات الطارئة والإدارة الاستباقية والتحديثات المنتظمة لنظام دورة حياة التطوير الآمن نفسه.
- يجب أن يتوافق كود التطبيقات التي تتعامل مع المعلومات السرية مع معايير الترميز الآمن.
- يجب أن يكون جميع المطورين الذين تم نشرهم لتطوير العمل في النطاق قد خضعوا للتدريب على الترميز الآمن.
- يجب على مقدم العرض مراجعة واختبار جميع رموز التطبيق بحثًا عن نقاط الضعف الأمنية والأبواب الخلفية قبل النشر باستخدام مجلس الضمان الصحي.
- يجب على مقدمي العرض الإلتزام بسياسة إدارة الدخول، بما يتعلق بتقييد الدخول عن بعد VPN من خارج المملكة العربية السعودية لأي نظام ذو تصنيف حساس.
- يجب حل جميع النتائج الأمنية ونقاط الضعف القابلة للاستغلال قبل إصدار التطبيق.
- أي استثناء لهذا لن يكون إلا بموافقة المدير التنفيذي لإدارة الأمن السيبراني والمخاطر في مجلس الضمان الصحي.

الاستجابة للحوادث:

- يجب إخطار مجلس الضمان الصحي كتابيًا خلال ٢٤ ساعة من أول إشارة أو تقرير عن انتهاك محتمل أو كشف غير مقصود للمعلومات السرية أو النظام التابع لمجلس الضمان الصحي.
- يجب أن تتم الاستجابة للحوادث التي قد تؤثر على المعلومات أو الأنظمة السرية بسرعة وبموارد كافية. يجب على مقدم العرض تعيين فريق محترف للاستجابة للحوادث من طرف ثالث إذا لم تكن الموارد الداخلية تتمتع بالمهارة أو التوافر الكافي.
- يحق لمجلس الضمان الصحي الاطلاع على كافة أدلة الاستجابة للحوادث والتقارير والاتصالات والمواد ذات الصلة عند الطلب.
- إذا طلب مجلس الضمان الصحي، أو إذا كان ذلك مطلوبًا بموجب القانون، يجب على مقدم العرض إخطار جميع الأشخاص المتأثرين بالحادث كتابيًا، على نفقته الخاصة.

التدقيق والتفتيش:

- يجب على مقدمي العروض إشراك طرف ثالث مستقل سنويًا لتقييم الأمان التقني لأنظمة مقدم العرض. يجب أن تتضمن هذه المراجعات اختبارات الاختراق من منظور مهاجم خارجي ومستخدم داخلي يتمتع بامتيازات مشتركة وإدارية. يجب أن تشمل اختبارات الاختراق جميع الأنظمة المعرضة للإنترنت وأي أنظمة، داخلية أو خارجية، تتعامل مع المعلومات السرية. يجب أن يكون هذا التقييم السنوي على نفقة مقدم العرض وحده.

إعدادات النظام والصيانة:

- يجب أن تظل جميع أنظمة التشغيل والخوادم والبرامج وأجهزة الشبكة المضمنة في النطاق محدث ومحمي بشكل فعال.
- يجب على مقدمي العروض الحفاظ على إرشادات تكوين أفضل الممارسات الأمنية التقنية لجميع هذه الأنظمة وتحديثها سنويًا على الأقل.
- يجب تثبيت جميع حزم التحديثات الأمنية على الأنظمة خلال إطار زمني محدد.